

Réponses au exercices :

Étude de cas 1 : « E-Com Shop »

Énoncé :

Une entreprise de vente en ligne a subi une fuite de données : des noms, adresses et numéros de téléphone clients ont été exposés sur Internet.

Questions :

1. Quelles erreurs ont pu être commises ?
2. Rédiger une réponse d'urgence à envoyer aux clients.
3. Proposer 3 actions concrètes pour éviter que cela ne se reproduise.

Réponses :

1. Erreurs possibles :

- Absence de pseudonymisation ou anonymisation des données.
- Base de données non chiffrée.
- Mots de passe faibles ou exposés dans les fichiers.
- Logs mal configurés (affichant trop d'informations).
- Pas de pare-feu ou système de détection d'intrusion.
- Accès non restreint aux sauvegardes ou fichiers sensibles.

2. Réponse d'urgence aux clients :

Objet : Notification importante – Fuite de données

Cher(e) client(e),

Nous avons détecté une fuite de données contenant certains de vos renseignements (nom, adresse, numéro de téléphone).

Nous avons immédiatement sécurisé nos systèmes et lancé une enquête approfondie. À ce jour, aucun usage frauduleux n'a été détecté.

Nous vous prions de nous excuser pour cette situation. Pour toute question, contactez-nous sur :
support@ecomshop.ma

Cordialement,

L'équipe E-Com Shop

3. Actions concrètes à mettre en place :

- Chiffrer toutes les données sensibles (avec AES).
- Activer la double authentification pour accéder à l'administration.
- Utiliser un fichier .env sécurisé, et ne jamais exposer les mots de passe dans le code.

Exercice 2 : Analyse de fichiers de logs

Énoncé :

On vous fournit le fichier log_acces.txt contenant les lignes suivantes :

2025-05-10 14:01 - Login utilisateur: U123 depuis IP: 192.168.1.5

2025-05-10 14:02 - Login utilisateur: U123 depuis IP: 192.168.1.200

2025-05-10 14:03 - Login utilisateur: U123 depuis IP: 192.168.1.201

2025-05-10 14:04 - Login utilisateur: U123 depuis IP: 192.168.1.202

Questions :

- Identifier les accès suspects.
- Proposer une action (blocage IP ? alerte ? etc.)

Réponses :

- **Accès suspects :**
 - L'utilisateur U123 s'est connecté depuis **4 IP différentes en 4 minutes**.
 - Cela peut indiquer un **vol de session ou une attaque**.
- **Action recommandée :**
 - Générer une **alerte de sécurité automatique**.
 - Bloquer temporairement l'accès depuis les IPs suspectes.
 - Imposer une nouvelle authentification

Exercice 3 : Obscurcissement de code JavaScript

Énoncé :

Code original :

```
function afficherMessage() {  
  const message = "Bienvenue sur notre site";  
  console.log(message);  
}
```

Questions :

- Utiliser un outil comme Obfuscator.io pour transformer ce code.
- Comparer les deux versions.
- Expliquer pourquoi cela protège le code contre les pirates.

Réponses :

- **Version obfusquée** (via <https://obfuscator.io>) :

```
function _0xabc(){const _0x1a="Bienvenue sur notre site";console['log'](_0x1a);}
```

- **Comparaison :**
 - L'original est **facilement lisible et modifiable**.
 - L'obfusqué est **illisible** pour un humain sans outils de décryptage.
- **Pourquoi cela protège :**
 - Cela **ralentit le vol de code** ou la compréhension de la logique métier.
 - Ce n'est pas une vraie sécurité, mais une **mesure complémentaire** à appliquer en production.

Étude de cas 2 : CNDP vs RGPD

Énoncé :

Une startup marocaine veut lancer son site web en France. Elle collecte les données des utilisateurs marocains et européens.

Questions :

- Compléter un tableau comparatif CNDP vs RGPD.
- Quelles démarches doivent être suivies pour rester conforme ?
- Proposer une politique de confidentialité simple pour l'Europe.

Réponses :

Tableau comparatif :

Élément	CNDP (Maroc)	RGPD (Europe)
Autorité de contrôle	CNDP (Commission Nationale)	CNIL (France), autres autorités nationales
Consentement	Obligatoire selon la loi 09-08	Consentement explicite et documenté
Droit à l'oubli	Oui, sur demande	Oui, formalisé dans l'article 17 du RGPD
Transfert hors territoire	Déclaration à la CNDP	Restrictions strictes (niveau de protection équivalent requis)

Démarches à suivre :

- Déclarer le traitement des données auprès de la CNDP (pour le Maroc).
- Désigner un **DPO (Data Protection Officer)** si activité régulière sur données en Europe.
- Mettre à jour la **politique de confidentialité** selon le RGPD.

Politique de confidentialité simplifiée (Europe) :

Nous collectons uniquement les données nécessaires à la gestion de votre commande : nom, adresse, e-mail.

Ces données sont stockées de manière sécurisée et ne sont jamais revendues.

Vous pouvez demander l'accès, la modification ou la suppression de vos données à tout moment en nous contactant à : dpo@notrestartup.com

Nous respectons la réglementation RGPD en vigueur.

Exercice 4 : Rédiger une politique de confidentialité

Énoncé :

Créer une politique de confidentialité pour une application fictive de réservation de taxi.

Doit inclure :

- Types de données
- But de la collecte
- Droits des utilisateurs
- Durée de conservation

- Sécurité

Réponse : Politique de confidentialité – Appli TaxiGo

Politique de confidentialité – TaxiGo

1. Données collectées :

- Nom, prénom, numéro de téléphone, adresse e-mail, position GPS.

2. Finalité :

- Réserver un taxi rapidement et vous géolocaliser.

3. Vos droits :

- Accès, modification, suppression de vos données.
- Suite à vos demandes sur : espaceprive@taxigo.ma

4. Durée de conservation :

- Vos données sont conservées 12 mois maximum, sauf obligation légale contraire.

5. Sécurité :

- Les données sont stockées sur des serveurs sécurisés et chiffrés.
- L'accès est restreint aux employés autorisés.